Task ‘Cloud Migration and Integration Strategies’ Unit 9

Formative Task: Security Risk Assessment and Compliance Challenges

For this assessment, the imaginary company is a pharmaceutical company that is using a cloud solution to monitor the conditions of its refrigerated warehouses. Collection of information is being done using sensors to measure temperature and humidity and transmit these values to the cloud. The solution can then analyze the data and warn the person responsible when the values deviate from norm. Even though the system is not directly controlling medicines, a security problem could still have serious consequences if monitoring system stopped working or if data is to be altered.

One possible approach would be to integrate risk assessment and threat modelling. STRIDE could be used to determinate threats such as rough IoT device pretending to be an authorized IoT sensor, altering temperature values or preventing legitimate data from being delivered to the right destination. Such risks could be evaluated using qualitative methods such as likelihood and impact. This aligns with the NIST Cybersecurity Framework, which was developed to help organizations to identify, assess and manage cybersecurity risks.

(Pascoe, Quinn and Scarfone, 2024).

Using a framework is useful, but it should be combined with practical security testing.

Few controls could be introduced. Each sensor should have his own individual identity, rather than using for instance a shared password. Using this method would allow faster identification, blocking and removal of any rough or compromised device without impacting the others. Data should be encrypted in use, transit and at rest. Cloud accounts should use multi-factor authentication and password rotation, and

permission should be assigned on least privileged basis. These guidelines are supported by the broader risk management set of standards ISO/IEC 27002:2022, which provides practical guidelines to ensure confidentiality, integrity and availability maintained through a systematic approach.

(ISO, 2022).

Maintaining compliance also plays an important role. In case the solution contains information about employees that reside within the EEA, GDPR prerequisites must be applied. Collection of personal data must be done only for specific purposes, and the collection must be limited to only what is necessary, while organizations also need to consider proper retention which is aligned with the GDPR regulation.

(European Union, 2016).

The cloud provider could also be considered as data processor, that means that the company must ensure that the provider follows and provides appropriate security and privacy measures. International data that travels across jurisdiction boundaries could create additional compliance liability.

(European Union, 2016).

The company needs to have a well-defined and tested incident-response and disaster recovery process. NIST recommends integrating incident response into wider cybersecurity risk management as a preventive measure, rather than treating it as a recovery measure after an attack.

(Nelson et al., 2025).

IRP and DRP must therefore be tested on a regular basis, and staff must practice responding to events such as cloud outages or loss of sensor connectivity, to any negative event.

keeping security and compliance ongoing is a challenge. assessments on a regular basis, vulnerability testing and incident exercises help the company to proactively identify weaknesses as the cloud environment changes. Standards such as ISO/IEC 27002 and the NIST CSF can provide structure, but they still need to be specifically tailored to the needs and applied to the organization’s actual risks rather than simply being regarded as a generic checklist.

References

- European Union (2016) Regulation (EU) 2016/679 (General Data Protection Regulation). Official Journal of the European Union. Available at: https://eur-lex.europa.eu/eli/reg/2016/679/oj [Accessed: 18 September 2026].
- ISO (2022) ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: International Organization for Standardization. Available at: https://www.iso.org/standard/27001 [Accessed: 18 September 2026].

- Nelson, A., Rekhi, S., Souppaya, M. and Scarfone, K., (2025). Incident response recommendations and considerations for cybersecurity risk management. NIST special publication, 800. [Accessed: 17 September 2026].
- Pascoe, C., Quinn, S. and Scarfone, K. (2024) The NIST Cybersecurity Framework (CSF) 2.0. NIST Cybersecurity White Paper 29. Gaithersburg, MD: National Institute of Standards and Technology. Available at: https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20 [Accessed: 17 September 2026].

Use of Digital Tools

This document has been produced exclusively for educational purposes. Referenced content, copyrights, and trademarks, remain the sole property of the respective owner. ChatGPT 5.5 was used for some proofreading and clarity as well as literature exploration, language refinement, coding and programming techniques research. All academic writing, analysis, argumentation, and conclusions represent the original work of the author. AI tools were used for exploration, same way as academic literature exploration. No AI-generated content or code was directly copied into the final submission. Any use of content mentioned in this document is properly referenced to its original author and was used responsibly to ensure integrity and originality. All academic writing, analysis, argumentation, and conclusions represent my original work. I have used Artificial Intelligence responsibly and ethically, in accordance with the assignment brief. All AI use has been declared and evidenced.